

SÉCURITÉ DOCKER - GUIDE COMPLET

=====

1. SCAN DES IMAGES

Trivy - Scanner de vulnérabilités:

Installation:

```
curl -sfl https://raw.githubusercontent.com/aquasecurity/trivy/main/contrib/install.sh | sh
```

Commandes:

```
trivy image nginx:latest          # Scan basic

trivy image --severity HIGH,CRITICAL myapp # Filtre par sévérité

trivy image --format json myapp > report.json # Format JSON
```

2. DOCKERFILE BEST PRACTICES

Mauvais exemple

```
FROM ubuntu:latest

RUN apt-get update && apt-get install -y python3

COPY . .

CMD ["python3", "app.py"]
```

Bon exemple

```
FROM python:3.11-slim

RUN useradd -m -u 1000 appuser && \
    apt-get update && \
    apt-get clean

USER appuser

WORKDIR /app

COPY --chown=appuser:appuser requirements.txt .

RUN pip install --no-cache-dir -r requirements.txt
```

`COPY --chown=appuser:appuser . .`

`CMD ["python", "app.py"]`

3. RÉSEAU ET VOLUMES

- Utiliser des réseaux bridge isolés
- Ne pas exposer de ports inutiles
- Monter les volumes en lecture seule quand possible
- Utiliser des secrets Docker pour les informations sensibles

4. RUNTIME PROTECTION

- Limiter les ressources (CPU, mémoire)
- Utiliser AppArmor/SELinux
- Mettre à jour régulièrement les images de base
- Scanner les images dans le registre